

Bezpečnostné preskúmanie kódu integrácie s Tatra bankou

Výsledok preskúmania — podklad na odsúhlasenie

Prevádzkovateľ	Tobify s. r. o., Športová 707/43, 919 26 Zavar, IČO 56607016
Aplikácia	Faktero — fakturačný systém pre slovenské firmy, https://www.faktero.sk
Predmet	Integrácia s Tatra banka Premium API (AIS: účty, transakcie, výpisy; PIS: SEPA prevod)
Dátum preskúmania	11. augusta 2026
Verzia posudzovaného kódu	c71fc7c (nasadená v produkcii 11. 8. 2026, 19:16 UTC)
Vykonal	prevádzkovateľ, interné preskúmanie zdrojového kódu a nasadeného prostredia

Tento dokument uvádza **výsledok** preskúmania. Zdrojový kód nie je jeho súčasťou a nezverejňuje sa. Nálezy sú uvedené aj s tými, ktoré ešte nie sú uzavreté — dokument nie je marketingový a nič v ňom nie je prikrášené.

1. Zhrnutie

Preskúmanie našlo **tri nálezy so skutočným dopadom na bezpečnosť** (jeden vysoký, jeden vysoký na úrovni prevádzky servera, jeden stredný). **Všetky tri sú odstránené a náprava je nasadená v produkcii k 11. 8. 2026.** Ďalej sú uvedené tri nálezy nízkej alebo informatívnej závažnosti, ktoré zostávajú otvorené a nemajú vplyv na dôvernoscť prístupových údajov ani dát klienta.

Jadro integrácie — OAuth 2.0 s PKCE, serverová komunikácia s bankou, oddelenie dát medzi firmami a ochrana plánovaných úloh — bolo posúdené ako navrhnuté správne. Podrobnosti v časti 5.

2. Rozsah preskúmania

Posudzované bolo:

- získanie súhlasu klienta, prihlásenie cez banku a výmena autorizačného kódu za token (OAuth 2.0 Authorization Code + PKCE),
- uloženie, obnova a použitie prístupových a obnovovacích tokenov,

- volania AIS (účty, transakcie, mesačné výpisy) a PIS (SEPA prevod),
- oddelenie dát medzi firmami (viacnájomnosť) v databáze,
- ochrana plánovaných úloh a prijímača notifikácií,
- nakladanie s tajomstvami v prostredí servera a v logoch,
- závislosti tretích strán.

Mimo rozsahu: penetračné testovanie, posúdenie infraštruktúry poskytovateľa databázy a nezávislý audit treťou stranou. Preskúmanie je interné.

3. Metóda

1. Čítanie zdrojového kódu integrácie — všetky miesta, kde vzniká, ukladá sa, číta sa alebo odosiela prístupový údaj.
2. Kontrola nasadeného prostredia — prístupové práva k súboru s tajomstvami, TLS, presmerovanie na HTTPS, obsah logov.
3. Kontrola databázy — či sú citlivé polia uložené v čitateľnej podobe, či sú nad tabuľkami zapnuté prístupové politiky a či po dokončení prihlásenia ostávajú v databáze jednorazové hodnoty.
4. Kontrola závislostí (`npm audit`).
5. Po každej oprave opakované overenie na živej prevádzke.

4. Nálezy

#	Nález	Závažnosť	Stav
Z1	Tokeny do banky boli v databáze v čitateľnej podobe	Vysoká	Odstránené 11. 8. 2026
Z2	Súbor s tajomstvami na serveri bol čitateľný pre všetkých používateľov systému	Vysoká	Odstránené 11. 8. 2026
Z3	Parameter <code>state</code> v OAuth toku bol predvídateľný a nie jednorazový	Stredná	Odstránené 11. 8. 2026
Z4	Tajomstvo prijímača notifikácií sa dá poslať v adrese (query parameter)	Nízka	Otvorené — plánované
Z5	Odpoveď servera neobsahuje hlavičku HSTS	Nízka	Otvorené — plánované
Z6	Tri zraniteľnosti strednej závažnosti v nástrojoch na zostavenie	Informatívne	Bez dopadu na server

Z1 — Prístupové a obnovovacie tokeny boli uložené v čitateľnej podobe

Závažnosť: vysoká **Stav:** odstránené 11. 8. 2026

Zistenie. Polia `access_token` a `refresh_token` v tabuľke bankových pripojení boli uložené v pôvodnej podobe. Ostatné prihlasovacie údaje v systéme (platobná brána, GPS jednotka) pritom šifrované boli. Kto by získal čítací prístup k databáze alebo k jej záložnej kópii, mal by okamžite použiteľné kľúče k účtom klientov v banke.

Náprava. Obidve polia sa ukladajú šifrované algoritmom **AES-256-GCM**: 256-bitový kľúč odvodený funkciou SHA-256 z vyhradeného tajomstva v prostredí servera, **náhodný inicializačný vektor pre každú hodnotu** a autentizačná značka, takže zmena šifrovaného textu sa pri dešifrovaní odhalí. Token sa dešifruje výhradne v pamäti procesu v okamihu volania banky. Obnovený token sa ukladá opäť šifrovaný.

Overenie. Dve existujúce produkčné pripojenia boli prevedené do šifrovanej podoby. Po prevode aj po nasadení bolo overené, že sťahovanie z banky ďalej prebieha úspešne a že hodnoty v databáze už nie sú čitateľné.

Z2 — Súbor s tajomstvami mal príliš voľné prístupové práva

Závažnosť: vysoká (v kontexte prevádzky servera) **Stav:** odstránené 11. 8. 2026

Zistenie. Súbor `.env` na aplikačnom serveri, ktorý obsahuje klientske tajomstvo pre API banky, servisný kľúč databázy a šifrovací kľúč, mal prístupové práva umožňujúce čítanie ktorémukoľvek používateľovi systému.

Náprava. Práva zmenené na `600` — súbor smie čítať iba systémový účet, pod ktorým beží aplikácia. Súbor nikdy nebol a nie je súčasťou repozitára.

Z3 — Parameter `state` v OAuth toku bol predvídateľný

Závažnosť: stredná **Stav:** odstránené 11. 8. 2026, nasadené 19:16 UTC

Zistenie. Do autorizačnej výzvy sa ako parameter `state` posielal identifikátor bankového pripojenia. Ten je pre daného klienta nemenný a opakuje sa pri každom prihlásení aj pri každej obnove súhlasu. `state` má podľa OAuth 2.0 slúžiť ako ochrana proti podvrhnutiu požiadavky (CSRF) na kroku návratu z banky; hodnota, ktorá sa neobmieňa a nie je jednorazová, túto úlohu neplní.

Dopad bol obmedzený tým, že samotná výmena kódu za token je krytá PKCE — bez zodpovedajúceho `code_verifier`, ktorý neopúšťa server, sa autorizačný kód vymeniť nedá. Nález sme napriek tomu vyhodnotili ako potrebný odstrániť.

Náprava. `state` je teraz **32 náhodných bajtov z kryptografického generátora**, platí **15 minút** a je **jednorazový**: uloží sa k rozpracovanému pripojeniu, návrat z banky sa podľa neho vyhladá, skontroluje sa platnosť a hodnota sa okamžite zneplatní. Neplatný alebo uplynutý `state` návrat odmietne. Rovnako to platí pre prvé pripojenie aj pre obnovu súhlasu.

Z4 — Tajomstvo prijímača notifikácií je prijímané aj z adresy

Závažnosť: nízka **Stav:** otvorené, plánované

Zistenie. Prijímač notifikácií od banky prijíma zdieľané tajomstvo buď v hlavičke `X-Webhook-Secret`, alebo ako parameter v adrese (`?s=...`). Hodnoty v adrese sa bežne zapisujú do prístupových logov servera a sprostredkujúcich prvkov, kde majú dlhšiu životnosť než v hlavičke.

Kontext a plán. Endpoint zatiaľ **nie je v prevádzke** — banka nám nedodala dokumentáciu k formátu notifikácií, preto prijímač notifikáciu iba overí a uloží a **zámerne z nej nič neodvodzuje ani nespúšťa žiadnu synchronizáciu**. Bez nastaveného tajomstva sa notifikácia neukladá vôbec (zlyhanie do zatvorenej polohy). Podpora parametra v adrese vznikla ako ústupok pre prípad, že by odosielateľ nevedel poslať vlastnú hlavičku. Pri sprevádzkovaní notifikácií podľa dokumentácie banky doplníme overenie podpisu tela a spôsob prenosu tajomstva zúžime na hlavičku.

Z5 — Chýbajúca hlavička HSTS

Závažnosť: nízka **Stav:** otvorené, plánované

Zistenie. Server presmeruje `http://` na `https://` trvalým presmerovaním a používa TLS 1.3, ale neposiela hlavičku `Strict-Transport-Security`. Prehliadač si tak nezapamätá, že s doménou má komunikovať výhradne šifrované.

Plán. Doplniť do konfigurácie webového servera. Netýka sa komunikácie s bankou — tá prebieha zo servera a vždy cez TLS.

Z6 — Zraniteľnosti v nástrojoch na zostavenie

Závažnosť: informatívne **Stav:** bez dopadu na produkčný beh

Kontrola závislostí hlási tri zraniteľnosti strednej závažnosti. Všetky pochádzajú z jedného reťazca: nástroj príkazového riadka pre zostavenie mobilnej aplikácie → knižnica na úpravu projektu Xcode → knižnica na generovanie identifikátorov. Ide o **nástroje používané pri zostavovaní na vývojárskom stroji**, nie o kód, ktorý beží na serveri alebo obsluhuje požiadavky. Zraniteľnosť sa preto do prevádzky nedostáva. Plánujeme presunúť tieto nástroje medzi vývojové závislosti a aktualizovať ich.

5. Čo bolo preverené bez nálezu

- **PKCE.** `code_verifier` je 32 náhodných bajtov z kryptografického generátora, `code_challenge` je jeho SHA-256 (metóda `S256`). Verifier je jednorazový — po výmene kódu za token sa z databázy odstráni. Overené aj priamo v databáze: pri obidvoch produkčných pripojeniach je pole prázdne.
- **Klientske tajomstvo** existuje výhradne v prostredí servera. Neposiela sa do prehliadača ani do mobilnej aplikácie a nezapisuje sa do logov.
- **Komunikácia s bankou prebieha výlučne zo servera.** Prehliadač ani mobilná aplikácia sa na API banky nepripájajú a token sa k nim nikdy nedostane.

- **Oddelenie dát medzi firmami.** Nad tabuľkami bankových pripojení, účtov, transakcií a výpisov je zapnuté row-level security; politiky sa viažu na členstvo používateľa vo firme. Servisný kľúč databázy, ktorý politiky obchádza, sa používa len na serveri v plánovaných úlohách a v miestach, kde už prebehlo overenie príslušnosti k firme.
- **Plánované úlohy** sú chránené tajným tokenom, ktorý sa porovnáva **v konštantnom čase**; nenastavený token znamená odmietnutie, nie voľný prechod.
- **Prijímač notifikácií zlyháva do zatvorenej polohy** a neukladá hlavičku `Authorization` ani cookies.
- **Logovanie.** Logujú sa adresy volaní, HTTP kódy a identifikátor požiadavky (`X-Request-ID`) kvôli dohľadateľnosti na strane banky. Tokeny, klientske tajomstvo ani heslá sa do logov nezapisujú. Pri chybe banky sa loguje skrátené telo odpovede (400 znakov) na účely diagnostiky.
- **Prenosový kanál.** TLS 1.3, `http://` sa presmeruje na `https://` .
- **Opakovateľnosť.** Transakcie sa ukladajú podľa identifikátora z banky, takže opakovaný beh sťahovania nevytvorí duplicitu. Sťahovanie beží po pripojeniach nezávisle — zlyhanie jedného klienta neovplyvní ostatných.
- **Chybové stavy.** Odpovede banky sa používateľovi nezobrazujú surové; prekladajú sa do zrozumiteľnej správy a stav pripojenia sa označí ako chybný.
- **Súbory výpisov** sú v súkromnom úložisku, prístup je viazaný na členstvo vo firme a vydávajú sa časovo obmedzené podpísané odkazy.

6. Uchovávanie a mazanie dát

- Transakcie a výpisy sa uchovávajú, kým je pripojenie aktívne — slúžia na párovanie úhrad s faktúrami a ako podklad pre účtovníctvo klienta.
- Odpojením banky sa zmažú účty a s nimi kaskádovo transakcie a výpisy danej firmy.
- Súhlas klienta je časovo obmedzený zo strany banky; po jeho uplynutí sa čítanie zastaví, kým klient súhlas neobnoví.
- Databáza je prevádzkovaná v regióne Európskej únie.

7. Zostatkové riziká a obmedzenia

1. **Preskúmanie je interné**, nie audit nezávislej tretej strany a nezahrňalo penetračné testovanie.
2. **Notifikácie z banky nie sú v prevádzke.** Integrácia beží na plánovanom sťahovaní (transakcie denne o 9:20, výpisy o 5:45). Overenie podpisu notifikácií doplníme, keď dostaneme dokumentáciu k ich formátu.
3. **Platobná služba (PIS) nebola dosiaľ vykonaná v ostrej prevádzke.** Kód je dokončený a overený proti sandboxu; ostré overenie je pripravené.
4. **Nálezy Z4 a Z5 zostávajú otvorené** v rozsahu a s plánom uvedeným vyššie.

8. Záver

Nálezy, ktoré ohrozovali dôvernosť prístupových údajov ku klientskym účtom (Z1, Z2) alebo odolnosť autorizačného toku (Z3), boli odstránené a náprava je overená v produkčnej prevádzke. Otvorené nálezy sú nízkej závažnosti, netýkajú sa komunikácie s bankou a majú stanovený spôsob riešenia.

Prevádzkovateľ je pripravený doplniť ktorúkoľvek časť dokumentu, doložiť podrobnosti k jednotlivým nálezom alebo prejsť konkrétne miesto integrácie na spoločnom hovore.

Kontakt: Tobify s. r. o. · info@faktero.sk · +421 902 101 967